**FACULTAD DE DEFENSA NACIONAL (FADENA)**

**LICENCIATURA EN CIBERDEFENSA**

ASIGNATURA: TECNOLOGÍA OPERATIVA (2026)

# SOLUCIONARIO OFICIAL

*Actividades de Verificación y Análisis*

Unidad 2 — Documentos de Cátedra N° 5 al 8

Versión 1.0 — 2026

*Documento de uso interno — Cátedra Tecnología Operativa*

## Nota para el alumno

Este solucionario contiene las respuestas oficiales de cátedra para todas las Actividades de Verificación y Análisis de los Documentos N° 5 al 8. Fue elaborado para que puedas autoevaluar el nivel y la profundidad de tus respuestas. Una respuesta correcta no se limita a nombrar el concepto: debe argumentar la relación entre el principio teórico y el efecto operativo o de seguridad, con referencia al contexto de la infraestructura crítica y la tríada AIC.

Las respuestas están organizadas según el Documento de Cátedra de origen, respetando el orden de las preguntas tal como fueron presentadas.

# **Documento de Cátedra N° 5 —** El PLC — Arquitectura y Ciclo de Operación

**Actividad 1.** Explique por qué el PLC ejecuta su programa sobre una Tabla Imagen de entradas y no directamente sobre los valores en tiempo real de los sensores. ¿Qué ventaja operativa aporta y qué vulnerabilidad introduce?

### ▶ Respuesta oficial de cátedra:

**Razón del diseño:** Si la CPU leyera los sensores físicos en tiempo real durante cada instrucción del programa, distintas partes del mismo programa podrían ver valores diferentes del mismo sensor (si el sensor cambió de estado entre dos lecturas sucesivas). Esto introduciría inconsistencias lógicas e indeterminismo en el control. La Tabla Imagen es una fotografía congelada del estado de todas las entradas al inicio de cada ciclo de scan, garantizando que el programa trabaje con un conjunto coherente y estable de datos durante toda su ejecución.

**Ventaja operativa:** Garantiza el determinismo temporal. El tiempo de ejecución del programa es predecible porque no depende del tiempo de respuesta de los sensores físicos. La CPU siempre lee de memoria RAM (velocidad constante), nunca de hardware externo (velocidad variable). Esto es un requisito innegociable en OT, como se estableció en el Documento N° 1.

**Vulnerabilidad introducida:** El ataque de race condition. Existe una ventana de tiempo entre el final de la Fase 1 (lectura de entradas hacia la tabla imagen) y el inicio de la Fase 2 (ejecución del programa sobre la tabla). Si un adversario con acceso de escritura a la memoria del PLC puede modificar la Tabla Imagen durante esa ventana, el programa tomará decisiones basadas en datos falsos sin que ningún sensor haya sido comprometido. El ataque es invisible a nivel de señal física, pero surte efecto en el plano lógico de la CPU.

**Actividad 2.** Un adversario logra acceso de escritura a la Memoria de Programa de un PLC que controla válvulas de distribución de agua potable. No desea generar una alarma inmediata. ¿Qué modificación sutil podría realizar?

### ▶ Respuesta oficial de cátedra:

El adversario puede modificar el valor de tiempo preestablecido (PT) de un temporizador TON que controla la apertura de una válvula de dosificación de cloro o de una válvula de descarga. Por ejemplo: cambiar PT de 500 ms a 5000 ms. Esta modificación tiene solo un bit o unos pocos bytes de diferencia en la memoria de programa.

Efecto en el ciclo de scan: en cada ciclo en que se ejecuta ese rung del programa, el temporizador tardará 10 veces más en completarse. La válvula de seguridad o dosificación quedará 4,5 segundos adicionales en un estado incorrecto por cada ciclo de operación, sin que la HMI muestre ninguna alarma (porque el parámetro de alarma sigue siendo el mismo y la lógica de control no lo detecta como fuera de rango).

A largo plazo, la acumulación de estos retardos puede producir subdosificación crónica de cloro (riesgo biológico gradual), sobrecalentamiento de equipos por ventilación insuficiente, o fatiga de válvulas por operación fuera de ciclo. El daño diferido nunca activa una alarma puntual, haciendo muy difícil la correlación forense con el cambio en el código.

Este tipo de modificación es el vector más silencioso y peligroso: una diferencia de un único entero en memoria, invisible en una revisión superficial del diagrama Ladder, con consecuencias físicas que se acumulan durante días o semanas antes de producir un evento observable.

**Actividad 3.** Compare los modos de operación RUN y STOP desde la perspectiva de la tríada AIC. ¿Cuál de los tres principios es el más directamente afectado por un comando de STOP no autorizado?

### ▶ Respuesta oficial de cátedra:

**Modo RUN:** Es el estado operacional normal. El PLC ejecuta continuamente el ciclo de scan; las salidas físicas responden al programa; el proceso físico está bajo control. En este modo, la Disponibilidad del proceso está garantizada, la Integridad de los datos de control está activa, y la Confidencialidad (menor relevancia en OT) es como siempre.

**Modo STOP:** La ejecución del programa se suspende. Las salidas adoptan un estado predefinido (generalmente desactivadas). El proceso físico se detiene o entra en estado de falla. Cualquier modificación del programa queda reflejada en la próxima ejecución.

**Principio más directamente afectado:** Disponibilidad.

Un comando de STOP no autorizado suspende inmediatamente el proceso de control. En entornos OT, donde la Disponibilidad es la prioridad máxima de la tríada AIC, este es el ataque más directo: interrumpe la continuidad operativa del proceso físico sin necesidad de comprometer la integridad de los datos ni violar la confidencialidad de ninguna información. El caso documentado del ataque a la red eléctrica ucraniana de 2015 (BlackEnergy) es el ejemplo paradigmático: los PLCs recibieron un comando remoto de STOP que abrió los disyuntores y dejó sin electricidad a 230.000 personas, todo sin modificar un solo byte de la lógica de control.

**Actividad 4.** Análisis de Caso: El Scan Time del PLC principal aumentó de 15 ms a 85 ms en los últimos tres meses sin nuevos programas cargados ni fallas de hardware. ¿Qué hipótesis de ciberataque plantearía?

### ▶ Respuesta oficial de cátedra:

**Hipótesis principal:** Presencia de código malicioso inyectado en la Memoria de Programa o en el Firmware de la CPU.

El Scan Time es la métrica directa del tiempo que demora la CPU en completar un ciclo completo (lectura de entradas → ejecución del programa → escritura de salidas → comunicaciones). Un aumento de 15 ms a 85 ms sin nuevos programas cargados indica que la CPU está ejecutando más instrucciones de las que el programa legítimo requiere, o que el firmware está realizando operaciones adicionales no autorizadas.

**Escenarios posibles:**

(a) Código malicioso en la Memoria de Programa: un adversario con acceso de escritura insertó rungs adicionales ocultos o rutinas en Texto Estructurado que consumen ciclos de CPU sin producir cambios visibles en la HMI.

(b) Firmware comprometido: una versión maliciosa del firmware de la CPU fue cargada mediante el puerto de programación o de diagnóstico, agregando rutinas de espionaje, comunicación encubierta o preparación de un payload futuro que consume ciclos adicionales.

**Verificación:** (1) Comparar byte a byte el programa activo en la CPU contra la versión firmada y aprobada almacenada en el sistema de gestión de cambios. (2) Verificar la versión del firmware instalada contra la versión oficial del fabricante. (3) Monitorear el tráfico de red del puerto de comunicaciones del PLC en busca de conexiones salientes no autorizadas. (4) Revisar el log de acceso al puerto de programación en busca de sesiones no documentadas.

# **Documento de Cátedra N° 6 —** Programación del PLC — Ladder y Bloques de Función

**Actividad 1.** Identifique en el programa Ladder de la Sección 4 cuál es el elemento que implementa la función de self-seal. Explique su necesidad operativa y qué sucedería si fuera eliminado por un atacante.

### ▶ Respuesta oficial de cátedra:

**Elemento identificado:** El contacto Normalmente Abierto (NA) de la variable interna SEAL_BOMBA, ubicado en la rama inferior en paralelo con el contacto de MARCHA_PB en la Red 1 (R001).

La Red 2 (R002) activa este bit cuando BOMBA_M se energiza: el self-seal se 'cierra' en el mismo ciclo en que arranca la bomba. Desde ese momento, aunque el operador suelte el pulsador de MARCHA (que vuelve a 0), el camino de corriente se mantiene a través del contacto de SEAL_BOMBA, que permanece activo mientras BOMBA_M esté encendida.

**Necesidad operativa:** Sin self-seal, la bomba solo correría mientras el operador mantuviera físicamente presionado el pulsador de MARCHA. Al soltarlo, la bomba se detendría. Esto haría imposible cualquier operación autónoma o supervisada en una planta real, donde el operador no puede permanecer con el dedo en el botón durante horas.

**Efecto de su eliminación por un atacante:** Si un adversario elimina el contacto SEAL_BOMBA de la Red 1, la bomba solo funciona mientras se mantiene presionado MARCHA_PB. En el momento en que el operador suelta el pulsador (lo cual ocurrirá siempre), la bomba se detiene. El proceso queda inoperativo sin ninguna alarma visible en la HMI: la bomba simplemente 'no arranca' de forma sostenida. Dependiendo del contexto (sistema de refrigeración, distribución de agua, bombeo de combustible), esto puede causar desde una parada de producción hasta una falla catastrófica por pérdida de refrigeración.

**Actividad 2.** Un temporizador TON controla el tiempo de apertura de una válvula de descarga en una caldera. El valor programado es PT = 2s. Un adversario modifica este valor a PT = 120s. ¿Qué consecuencia física y qué principio AIC está en juego?

### ▶ Respuesta oficial de cátedra:

**Consecuencia física:** La válvula de descarga es el mecanismo de alivio de presión de la caldera. El TON con PT = 2s controla cuánto tarda el sistema en habilitar la apertura de la válvula tras recibir la señal de condición de alta presión. Con PT = 2s, el sistema reacciona en 2 segundos. Con PT = 120s, la válvula tardará 2 minutos en abrirse.

Durante esos 118 segundos adicionales, la presión en la caldera continuará acumulándose sin vía de escape. Dependiendo de la tasa de aumento de presión y de la resistencia mecánica de la caldera, el resultado puede ir desde daños a sellos y tuberías hasta una rotura explosiva del recipiente a presión, con consecuencias potencialmente letales para el personal de planta.

**Principio AIC atacado primariamente:** Integridad de la lógica temporal.

La lógica de control continúa ejecutándose correctamente desde el punto de vista formal: el temporizador funciona, la válvula eventualmente se abre. Sin embargo, el parámetro temporal fue manipulado para que la protección sea inefectiva en la ventana crítica. La HMI no muestra ninguna alarma (el sistema está 'funcionando normalmente') y el código fuente del programa sigue siendo idéntico salvo por un único valor entero. Es el ejemplo más claro de un ataque silencioso a la integridad de la lógica de control con consecuencias físicas diferidas.

**Actividad 3.** Compare el impacto de un ataque de DoS (comando STOP al PLC) con un ataque de manipulación de lógica en términos de: velocidad de detección, reversibilidad del daño y detectabilidad por herramientas de red.

### ▶ Respuesta oficial de cátedra:

**1. Velocidad de detección:**

DoS (STOP): inmediata. El proceso se detiene abruptamente, las salidas caen a su estado de falla, las alarmas de 'proceso detenido' se activan en segundos, y el operador percibe el evento directamente. No hay margen de invisibilidad.

Manipulación de lógica: puede pasar desapercibida durante horas, días o semanas. El proceso continúa ejecutándose dentro de sus parámetros aparentemente normales. La HMI no muestra alarmas. Solo una auditoría específica del código del programa o un análisis del comportamiento físico del proceso (más lento, más caliente, con presiones ligeramente anómalas) puede revelar la modificación.

**2. Reversibilidad del daño físico:**

DoS (STOP): el daño físico es generalmente nulo o mínimo si el proceso entra en un estado de falla seguro (Fail-Safe). Reiniciar el PLC en modo RUN restablece el control en minutos.

Manipulación de lógica: el daño físico puede ser irreversible. Un motor quemado por operar en seco, una caldera dañada por sobrepresión, o un compresor destruido por falta de interlock de seguridad no se recuperan con un comando de software. El costo es la reparación o reposición del hardware físico.

**3. Detectabilidad por herramientas de seguridad de red:**

DoS (STOP): un IDS de red puede detectar el paquete de comando STOP si conoce la firma del protocolo (ej. un comando de modo STOP en EtherNet/IP o en el protocolo S7 de Siemens). El evento queda registrado en el tráfico de red.

Manipulación de lógica: completamente invisible para las herramientas de seguridad de red convencionales. Un paquete de escritura a la Memoria de Programa del PLC puede ser indistinguible de una actualización legítima de programa, a menos que exista un sistema de gestión de cambios (Change Management) que verifique la firma del código autorizado.

**Actividad 4.** Análisis de Caso: Explosión de un compresor. El programa activo difiere del respaldo en un único rung: el contacto NA del sensor HIGH_PRESS fue reemplazado por una variable interna siempre en 0. ¿Qué función fue deshabilitada? ¿Cuál fue el mecanismo del daño? ¿Qué vector investigaría?

### ▶ Respuesta oficial de cátedra:

**Función de seguridad deshabilitada:** El interlock de presión máxima (HIGH_PRESS). Este contacto NA en el rung de control del compresor debía activarse cuando el sensor detectara presión máxima, habilitando el circuito que detenía el compresor o abría la válvula de alivio. Al reemplazarlo por una variable que siempre vale 0, el contacto NA nunca conduce: el interlock de alta presión quedó permanentemente deshabilitado.

**Mecanismo del daño físico:** El compresor continuó operando y acumulando presión internamente sin que ninguna señal del sensor —por alta que fuera— pudiera activar el mecanismo de parada o alivio. La presión escaló hasta superar los límites mecánicos de diseño del recipiente, produciendo la rotura explosiva. El sensor seguía funcionando correctamente y enviando la señal de alta presión, pero el programa de control la ignoraba estructuralmente.

**Vector de acceso a investigar prioritariamente:** La explotación del puerto de comunicaciones del PLC mediante un protocolo sin autenticación (Modbus TCP, EtherNet/IP). Dado que la modificación fue quirúrgica (un único cambio en un contacto de un rung específico), sugiere conocimiento previo del programa y acceso de escritura a la memoria de programa, compatible

con un acceso remoto a través de la red IT/OT convergida. Se investigará: el log de acceso al PLC, las sesiones de escritura al puerto de programación, y las conexiones activas en la red OT en el período previo al incidente.

# **Documento de Cátedra N° 7 —** La RTU — Control Distribuido en el Territorio

**Actividad 1.** Explique la diferencia funcional entre el polling periódico y el Reporte por Excepción (RBE). ¿En qué escenario de ataque el RBE representa un riesgo mayor? Justifique.

### ▶ Respuesta oficial de cátedra:

**Polling periódico:** El MTU interroga a cada RTU en secuencia a intervalos regulares de tiempo (ej. cada 30 segundos). La RTU responde con sus datos de estado en cada ciclo, haya o no cambios en el proceso. El tráfico es predecible, continuo y fácilmente monitoreable.

**Reporte por Excepción (RBE):** La RTU solo transmite al MTU cuando una variable cambia de valor o supera un umbral predefinido. En condiciones estables, no hay tráfico. Esto reduce el ancho de banda consumido, pero introduce una asimetría importante: el operador solo conoce cambios reportados, no el estado actual confirmado de la RTU.

**Escenario de mayor riesgo para el RBE — Man-in-the-Middle con supresión selectiva:**

Un adversario posicionado entre la RTU y el MTU puede implementar un ataque de supresión selectiva: deja pasar los paquetes de polling normales para que el enlace aparezca activo y sin anomalías, pero filtra y descarta selectivamente los paquetes de Reporte por Excepción que contienen las alarmas del proceso.

Resultado: el operador ve la planta en estado 'normal' (ausencia de reportes de excepción se interpreta como ausencia de cambios), el enlace de comunicación aparenta estar activo, y la condición de alarma real en el campo nunca llega al centro de control. En un sistema de polling puro, la supresión generaría la ausencia de la respuesta al polling, lo que activaría alarmas de 'pérdida de comunicación'. En RBE, el silencio es la condición esperada y no genera alertas.

**Actividad 2.** Un sistema SCADA de distribución de agua opera con RTUs conectadas mediante red celular 4G de un único proveedor. ¿Qué contramedidas recomendaría para garantizar la Disponibilidad ante falla del proveedor y ante Jamming deliberado?

### ▶ Respuesta oficial de cátedra:

**Ante falla del proveedor (corte de red celular):**

Implementar comunicaciones redundantes sobre medios físicos diferentes (diversidad de medios). Por ejemplo: canal primario por red celular 4G y canal de respaldo por radio VHF/UHF punto a punto o enlace satelital VSAT. Ante la caída del proveedor celular, el sistema conmuta automáticamente al canal de respaldo sin intervención del operador.

Adicionalmente, configurar la RTU en modo Stand-Alone con umbrales de acción local documentados, de forma que el proceso sea gestionado localmente hasta que se restaure la comunicación.

**Ante Jamming deliberado:**

La redundancia en medios diferentes es también la contramedida principal: un atacante que satura la frecuencia celular no puede simultáneamente saturar la frecuencia de radio y el enlace satelital con los mismos medios y desde la misma posición. Se añade: (1) configuración de alarmas de pérdida de comunicación en el MTU con tiempos de alerta mínimos; (2) protocolos de respuesta documentados y entrenados ante pérdida de enlace, incluyendo el despliegue de equipos en campo para control local; y (3) el uso de antenas direccionales en los enlaces de radio, que aumentan la potencia de señal en el receptor legítimo y dificultan el Jamming efectivo.

**Actividad 3.** Compare la superficie de ataque de un PLC de planta con la de una RTU en una estación de bombeo remota. Identifique tres vectores exclusivos de la RTU y su impacto en la defensa en profundidad.

### ▶ Respuesta oficial de cátedra:

Un PLC de planta generalmente opera en una sala de control con acceso físico restringido, personal permanente presente, y conexión a la red industrial local en un entorno controlado. Sus vectores de ataque más relevantes son los de red (explotación de protocolos) y firmware.

**Tres vectores exclusivos de la RTU en campo remoto:**

(1) Acceso físico al gabinete sin personal presente: la RTU opera en una ubicación geográficamente remota, sin supervisión humana permanente. Un adversario puede acercarse al gabinete, abrirlo y conectar directamente su laptop al puerto de comunicaciones de la RTU, emitiendo comandos o cargando firmware malicioso sin necesidad de explotar ninguna vulnerabilidad de red. El gabinete es la única barrera física.

(2) Interferencia del canal de comunicación de largo alcance (Jamming o intercepción RF): la RTU se comunica mediante radio, celular o satélite, medios que no existen en el entorno local del PLC. El canal de comunicación es susceptible a Jamming (pérdida de disponibilidad) e intercepción pasiva (exfiltración de inteligencia operativa), ataques que no aplican a un PLC con cable.

(3) Compromiso del protocolo sin autenticación sobre red compartida: las RTUs utilizan DNP3, IEC 60870-5-104 u otros protocolos sin autenticación que viajan sobre redes IP compartidas. A diferencia del PLC en la red local industrial, la RTU puede ser alcanzada desde cualquier nodo que tenga acceso a la red celular o VSAT compartida, ampliando enormemente la superficie de ataque remoto.

**Implicación para la defensa en profundidad:** La defensa no puede centrarse únicamente en el perímetro lógico (firewalls, segmentación de red). Debe operar en múltiples capas simultáneas: protección física del gabinete, cifrado y autenticación del protocolo, monitoreo pasivo del tráfico, redundancia de comunicaciones, y procedimientos de respuesta documentados ante pérdida de enlace. Ninguna capa es suficiente por sí sola.

**Actividad 4.** Análisis de Caso: Un adversario lleva semanas leyendo el tráfico de la red celular de RTUs de distribución de gas sin emitir ningún comando. ¿Qué información obtiene? ¿Qué fases del ataque prepara? ¿Qué medida lo habría impedido?

### ▶ Respuesta oficial de cátedra:

**Información obtenida mediante escucha pasiva:**

(1) Inteligencia operativa del proceso: valores de presión, temperatura y caudal en cada estación, lo que le permite identificar los puntos críticos de la red (nodos de mayor presión, estaciones con menor redundancia). (2) Direcciones de las RTUs (Dest_Addr en los paquetes DNP3): identifica cada RTU accesible y su dirección de protocolo para futuros comandos OPERATE. (3) Ciclo de polling del MTU: aprende el intervalo de interrogación de cada RTU, permitiéndole sincronizar ataques futuros entre dos ciclos de polling para maximizar la ventana de acción sin detección. (4) Eventos operativos normales: aprende cuándo se realizan mantenimientos, qué variaciones de presión son normales, qué valores no generan alarmas. Todo esto es inteligencia de reconocimiento de primera calidad.

**Fases del ataque en preparación:** Esta es la Fase 1 clásica de preparación (equivalente al reconocimiento del ataque Industroyer/Ucrania). El adversario está construyendo el conocimiento necesario para: (a) elegir las RTUs objetivo de mayor impacto; (b) diseñar comandos DNP3 OPERATE con las direcciones correctas; (c) identificar el momento óptimo para ejecutar el ataque (menor supervisión humana, mayor impacto operativo).

**Medida que lo habría impedido:** La implementación de cifrado en el protocolo de comunicación (DNP3 Secure Authentication v5 / IEEE 1815-2012 o un túnel VPN cifrado sobre el canal celular). Con el tráfico cifrado, el adversario puede capturar los paquetes pero no puede leer su contenido ni extraer las direcciones de RTU, los valores de proceso ni los ciclos de polling. El canal queda visible pero opaco.

# **Documento de Cátedra N° 8 —** La HMI — El Operador en el Loop de Control

**Actividad 1.** Un ingeniero propone conectar la HMI de una planta petroquímica directamente a la red corporativa para generar reportes automáticos. ¿Qué riesgo introduce y qué contramedida arquitectónica recomendaría?

### ▶ Respuesta oficial de cátedra:

**Riesgo de seguridad:** La HMI conectada directamente a ambas redes (IT corporativa y OT industrial) se convierte en un puente sin restricciones entre ellas. Un adversario que haya comprometido un equipo en la red corporativa (mediante phishing, malware, o exploit de vulnerabilidades en software de oficina) puede usar la HMI como nodo de pivoting para acceder a la red industrial, donde encontrará los PLCs, RTUs y servidores SCADA sin las protecciones perimetrales que normalmente protegen la red OT.

Este es exactamente el vector documentado en el ataque Industroyer/Ucrania 2015: el malware ingresó por la red IT corporativa mediante spear-phishing, y utilizó las HMIs de las subestaciones como trampolín hacia la red OT para acceder a los dispositivos de control de subestación.

**Contramedida arquitectónica:** Implementar una zona desmilitarizada OT (DMZ industrial) entre la red corporativa y la red OT. Esta DMZ contiene un servidor de datos unidireccional (data diode o historian replicado) que permite que los datos del proceso fluyan desde la red OT hacia la red IT para los reportes, pero impide físicamente cualquier conexión de retorno desde IT hacia OT. La HMI permanece exclusivamente en la red OT; el acceso a datos de producción desde la red corporativa se realiza a través del servidor historian de la DMZ, sin contacto directo con la HMI operativa.

**Actividad 2.** Clasifique el alarm flooding según la tríada AIC. ¿A cuál de los tres principios ataca primariamente? ¿Podría afectar también a los otros dos? Justifique.

### ▶ Respuesta oficial de cátedra:

**Principio atacado primariamente:** Disponibilidad de la respuesta cognitiva del operador.

El alarm flooding no bloquea el sistema técnico: el proceso sigue corriendo, la red sigue activa. Lo que colapsa es la capacidad del operador humano de procesar la información y tomar decisiones. La norma ISA-18.2 establece un máximo de 10 alarmas por minuto como umbral cognitivo manejable; por encima de ese límite, el operador no puede priorizar ni actuar con eficacia. El alarm flooding es, en esencia, una denegación de servicio cognitiva.

**Impacto en la Integridad:** Sí, puede afectar la Integridad. Para manejar el diluvio de alarmas, el operador puede recurrir a la supresión masiva del panel de alarmas (como ocurrió en el caso del Análisis de Caso de esta actividad). Desde ese momento, el operador pierde la visión del estado real del proceso: alarmas críticas genuinas quedan suprimidas junto con el ruido, y el operador toma decisiones basadas en una percepción incompleta o incorrecta de la realidad. Esto viola la Integridad de la conciencia situacional.

**Impacto en la Disponibilidad del proceso físico:** Si el operador, desbordado, toma una decisión incorrecta (parar el proceso para 'ganar tiempo' y analizar la situación) o deja de responder a alarmas genuinas (como la de un compresor en sobrepresión), las consecuencias se materializan en el proceso físico. El alarm flooding es, en el ataque a Ucrania 2015, el fuego de supresión que inmovilizó al defensor mientras se ejecutaba la maniobra principal.

**Actividad 3.** Compare el vector de ataque mediante USB (caso Stuxnet) con el vector de acceso remoto sin protección (caso Oldsmar). ¿Cuál representa mayor riesgo en el contexto actual de convergencia IT/OT?

### ▶ Respuesta oficial de cátedra:

**Vector USB (Stuxnet):**

Requiere que el atacante o un colaborador tenga acceso físico a las instalaciones para introducir la memoria USB infectada. El alcance inicial está limitado a equipos sin conexión a internet (air-gapped). Una vez dentro, el malware puede propagarse lateralmente, pero la infección inicial depende de la brecha del aislamiento físico. La contramedida principal es el bloqueo de puertos USB mediante política de grupo o bloqueadores físicos, sumado a controles de personal y acceso.

**Vector de acceso remoto sin protección (Oldsmar):**

No requiere ninguna presencia física. El atacante opera desde cualquier punto del mundo con conexión a internet. El único requisito es descubrir el software de acceso remoto expuesto (TeamViewer, VNC, RDP) y, en el caso de credenciales débiles o sin MFA, acceder sin más. Es completamente indetectable por controles físicos de acceso al sitio, y la ventana de ataque es permanente (cualquier hora, cualquier día).

**Mayor riesgo en el contexto actual:** El acceso remoto sin protección. La convergencia IT/OT y la necesidad operativa de soporte remoto de proveedores e ingenieros ha multiplicado las soluciones de acceso remoto instaladas en HMIs industriales, frecuentemente con configuraciones de seguridad deficientes. A diferencia del vector USB (que la industria ha mitigado ampliamente), el acceso remoto en entornos OT sigue siendo sistemáticamente subestimado. El incidente de Oldsmar (2021) demostró que una planta de agua puede ser comprometida desde internet en minutos, sin conocimiento especializado en OT, simplemente aprovechando un acceso remoto con contraseñas débiles.

**Actividad 4.** Análisis de Caso Integrador: Incidente en planta de tratamiento de agua. Identifique las fases del ataque, las técnicas utilizadas en cada fase, y los principios AIC vulnerados. ¿Qué contramedidas habrían interrumpido la cadena?

### ▶ Respuesta oficial de cátedra:

**Análisis de fases:**

Fase 1 — 02:15 al 02:23: Alarm Flooding (45 alarmas/min durante 8 min). Técnica: generación masiva de alarmas por manipulación de variables de proceso o inyección de mensajes de alarma al servidor SCADA. Principio atacado: Disponibilidad de la conciencia situacional y capacidad de respuesta del operador. El objetivo de esta fase no es dañar el proceso: es inhabilitar cognitivamente al defensor humano.

Fase 2 — 02:23: El operador silencia el panel de alarmas. El atacante logró su objetivo táctico: el operador humano, sin querer, colaboró con el ataque al suprimir su propio sistema de alerta. A partir de aquí, cualquier alarma genuina del proceso quedará ignorada.

Fase 3 — 02:23 al 02:31: Manipulación cinética del proceso (modificación de la dosificación de cloro). Técnica: comando directo al PLC o RTU a través de la HMI comprometida o del protocolo de control. Principio atacado: Integridad del proceso físico. El daño se produce durante la ventana creada por el alarm flooding.

Fase 4 — 02:31: La HMI muestra niveles de cloro normales. Técnica: falsificación del sinóptico o del valor reportado por el sensor (Sensor Spoofing a nivel de HMI o de señal de campo). Principio atacado: Integridad de los datos presentados al operador. Solo el sensor físico independiente (fuera de red) detecta la anomalía real.

Fase 5 — Posterior: Los datos del servidor historian de los últimos 20 minutos fueron sobreescritos con valores normales. Técnica: anti-forense mediante acceso de escritura al historian. Principio atacado: Integridad del registro histórico. El objetivo es destruir la evidencia del ataque y dificultar el análisis forense.

**Contramedidas que habrían interrumpido la cadena:**

(1) Gestión de alarmas ISA-18.2 con umbral de tasa máxima: un sistema racionalizado con pocas alarmas bien priorizadas es resiliente al flooding. Un umbral automático que alerte cuando la tasa supere 10 alarmas/min hubiera sido detectado como evento anómalo de seguridad. (2) Política de no silenciamiento masivo: procedimiento operativo que impide silenciar alarmas de seguridad (Prioridad 1) durante disturbios. (3) Autenticación multifactor para acceso al HMI y al servidor SCADA: habría impedido el acceso remoto no autorizado que ejecutó las fases 3 y 4. (4) Segmentación de red con DMZ OT: el historian no debería ser accesible de escritura desde la red IT. (5) Replicación del historian en servidor de auditoría con acceso de solo escritura inmutable: el anti-forense de la Fase 5 habría sido inútil porque una copia íntegra de los datos existiría en un servidor independiente.